

Objetivo

Este documento registra itens de segurança que podem ficar para depois do MVP, e também os ajustes mínimos que devem ser feitos antes de qualquer deploy público.

ANTES DO DEPLOY PÚBLICO - OBRIGATORIO

1. Remover jwt.secret do application.properties.
2. Remover senha do banco do application.properties.
3. Ler segredos por variáveis de ambiente ou secret manager.
4. Criar usuário de banco específico para a aplicação, sem usar root.
5. Desativar spring.jpa.show-sql em ambiente público.
6. Evitar spring.jpa.hibernate.ddl-auto=update fora de desenvolvimento.
7. Configurar CORS apenas para o domínio real do front-end.

POS-MVP - AUTH / USER

1. Adicionar rate limit em /user/login para reduzir brute force.
2. Adicionar rate limit em /user/register para reduzir spam de cadastro.
3. Exigir senha atual para troca de email.
4. Implementar revogação ou rotação de JWT após logout/troca de senha.
5. Avaliar refresh token com expiração curta do access token.
6. Melhorar mensagens e status HTTP para erros de autenticação/autorização.

POS-MVP - TOKEN / FRONT-END

1. Reavaliar armazenamento do JWT em localStorage.
2. Adicionar Content Security Policy quando houver build de produção.
3. Validar expiração do token no front-end antes de mostrar rotas privadas.
4. Manter o backend como fonte final de autorização, não o front-end.

POS-MVP - FOCUS

1. Adicionar paginação ou limite em /focus/all.
2. Adicionar quota de quantidade máxima de focuses por usuário.
3. Considerar reautenticação para deletar focus com muitas tasks.
4. Manter validação de dono via findByIdAndUser em todos os fluxos.

POS-MVP - TASK

1. Adicionar paginação ou limite em /task/focus/{focusId}/all.
2. Adicionar quota de quantidade máxima de tasks por focus/usuário.
3. Evitar carregamento N+1 no front-end quando houver muitos focuses.
4. Manter validação de dono via focus do usuário antes de update/delete/toggle.

POS-MVP - BANCO / INFRA

1. Separar perfis de configuração: dev, test e prod.
2. Usar migrations versionadas em vez de schema update automático em prod.
3. Revisar logs para evitar exposição de dados sensíveis.
4. Fazer backup e plano de rollback antes do deploy.

OBSERVAÇÃO SOBRE SQL INJECTION

Na auditoria atual não foi encontrada SQL Injection nos endpoints da aplicação. Os repositories usam métodos derivados do Spring Data JPA e não SQL concatenado com entrada do usuário. O item deve ser reavaliado se forem adicionadas queries manuais, nativeQuery, EntityManager, JDBC direto ou filtros dinâmicos.

PRIORIDADE PRÁTICA

Para finalizar o MVP, manter os fluxos principais estáveis. Antes de publicar, fazer pelo menos os itens obrigatórios de segredos/configuração. Os demais ficam